# SOFTWARE CHANGE IMPLEMENTATION REPORT

## CR-026: Forgot Password and Password Reset Feature

| Field | Details |
|---|---|
| Change Request ID | CR-026 |
| Change Request Title | Forgot Password and Password Reset Feature |
| Student Name | P.Tharanan |
| Student ID | JF/ICT/24/20 |
| Implementation Status | Completed |
| Date | 15 October 2026 |

# 1. Change Request Summary

## 1.1 Business Requirement

Users who forget their password are currently unable to access their account unless the password is changed through an existing administrative or manual process. The system should provide a secure and user-friendly Forgot Password facility that allows users to recover access to their account without requiring unnecessary administrator intervention. The feature should allow a user to request a password reset using their registered email address and securely create a new password. The password recovery process must protect user accounts from unauthorized password changes and must not weaken the existing authentication and authorization mechanism.

Before implementation:

- The Login page provides the existing username/email and password fields.
- Users can authenticate using their existing credentials.
- No Forgot Password option is currently available.
- Users who forget their password cannot initiate a password reset through the system.
- There is no dedicated password-reset request page.
- There is no dedicated password-reset process using a secure reset token.
- Existing authentication and authorization functionality is already implemented.
- Users must rely on an alternative/manual process if they forget their password..

# 1.2 Requested Change

Add a Forgot Password and Password Reset facility to the Student Management System.

The implementation must:

- Provide a Forgot Password link on the Login page.
- Allow users to enter their registered email address.
- Validate the submitted email address.
- Process the password-reset request securely.
- Generate a secure password-reset token.
- Provide the user with a password-reset link or equivalent secure reset mechanism.
- Ensure reset tokens have a limited validity period.
- Reject expired or invalid reset tokens.
- Ensure a reset token cannot be reused after a successful password reset.
- Provide a password-reset page.
- Allow users to enter a new password.
- Allow users to confirm the new password.
- Validate the new password according to the existing password policy.
- Securely hash the new password before storing it.
- Display a clear success message after a successful password reset.
- Display an appropriate error message for invalid or expired reset requests.
- Preserve the existing Login functionality.
- Preserve existing administrator authentication and authorization.
- Avoid exposing unnecessary sensitive account information.
- Prevent unauthorized users from changing another user's password.

# 2. Implementation

## 2.1 Implementation Summary

The CR-026 Forgot Password feature was added to the student login experience. Students can request a six-digit OTP at their registered email, verify it, and set a new password.

The backend looks up the email through the students table and permits only STUDENT accounts. It stores a bcrypt hash of a randomly generated OTP, emails the code through SMTP, verifies the code, then updates the linked user password with bcrypt inside a database transaction. The verified reset is invalidated after use. Existing login and administrator authorization remain unchanged.

## 2.2 Affected Files

| File | Change | Purpose |
|---|---|---|
| `backend/src/controllers/authController.js` | Modified | Validate requests, send and verify OTPs, and coordinate student password resets.. |
| `backend/src/models/authModel.jss` | New | Encapsulate password-reset table, student lookup, OTP, and password-update SQL.. |
| `backend/src/routes/authRoutes.jss` | Modifiedd | Expose student-only reset request, OTP verification, and password update routes.. |
| `frontend/src/components/LoginFormSection.jsx; frontend/src/pages/LoginPage.jsxs` | Modifiedw | Coordinate the email, OTP, password, loading, and error states.. |
| `frontend/src/services/authService.js; frontend/src/styles/login.css` | Modifiedd | Call reset endpoints and style the reset link and OTP form.. |
| `backend/package.json; backend/package-lock.jsonx` | Modifiedd | Add and lock Nodemailer for SMTP email delivery.. |

**Additional files: backend/src/models/authModel.js, frontend/src/components/LoginFormSection.jsx, frontend/src/services/authService.js, backend/package.json, backend/package-lock.json.**

# 2.3 Technical Changes

**Database Change**

The auth model creates student_password_reset_otps when the first reset request is made. It stores the student user ID, OTP hash, expiry, attempt count, request time, and verification time.
No users or students columns are added. Student email is resolved through the existing students.user_id relationship and the users role is checked.
The six-digit OTP is generated with a cryptographically secure random number generator; only its bcrypt hash is stored.
The OTP expires after ten minutes, allows at most five verification attempts, and a new OTP request is limited by a 60-second cooldown.
A purpose-limited JWT is issued after OTP verification and expires after ten minutes. The password update is restricted to the matching student, email, and STUDENT role.

**Student-only password recovery**

The email lookup joins students to users and requires users.role = STUDENT. Administrator accounts cannot request password changes through these endpoints.
Only the linked student account can be changed through these routes.
Unknown email addresses receive the same generic request response, avoiding unnecessary disclosure of student account existence.
The final password update repeats the student/email/role checks on the server; client-supplied user IDs are not trusted.
Reset request, OTP verification, and password update are exposed through dedicated student reset API routes.
Nodemailer sends OTP email using SMTP configuration read from backend environment variables.
The existing login endpoint and protected administrator routes are unchanged.

**Login-card reset experience**

The login card presents email entry, six OTP boxes, password and confirmation fields, errors, and completion feedback.
The OTP boxes support individual digit entry, keyboard navigation, and pasting a six-digit code.
Null or invalid timestamp values display as Never.

**Implementation Safeguards**

Email syntax and reset inputs are validated on the server. Passwords must be at least eight characters and the confirmation must match.
The new password is bcrypt-hashed before it is saved. Password update and reset-record deletion occur in one transaction.
An OTP challenge is deleted after a successful reset, preventing reuse; invalid, expired, or consumed reset tokens are rejected.

## 2.4 Implementation Logic

Receive and validate the requested email address.
Resolve the email to a student profile linked to a STUDENT user account.
Apply the OTP resend cooldown, generate a six-digit OTP, hash it, store its expiry, and send the code by SMTP.
Compare the submitted OTP with the stored hash and enforce its expiry and attempt limit.
Issue a short-lived, purpose-limited reset JWT only after successful OTP verification.
Validate the reset JWT, minimum password length, and matching password confirmation.
Within a transaction, update the matching student user with the bcrypt password hash and delete the OTP challenge.
Return a clear success message; reject invalid, expired, or previously used reset sessions.
Keep the existing username/password login and student management routes intact.

## 2.5 Error and Data Handling

Malformed email, invalid OTP, password mismatch, and expired or reused reset sessions produce error responses without updating a password.
An unknown email receives a generic response. OTP verification is capped at five attempts; OTP and reset-session validity are limited to ten minutes.
Passwords and OTP values are never returned to the client; only the OTP is sent to the registered student email.

# 3. Testing & Verification

## 3.1 Testing Approach

Verification included six browser UI captures using simulated API responses, backend syntax checks, targeted frontend lint, the frontend production build, and an invalid-email API check (400). Real SMTP delivery and database-backed password-reset integration were not run.
Verification methods:
Six reset-flow UI states (simulated API)
Backend JavaScript syntax checks
Targeted ESLint for changed frontend files
Frontend production build
Invalid email API response check (400)
Password reset controller/model source review
Real SMTP delivery and database-backed reset integration: not run
Environment: Development

# 4. Browser: Integrated browser; Test Role: Student; reset API responses simulated for UI evidence

## 4.1 Test Cases

| Test ID | Test Case | Expected Result | Actual Result | Status |
|---|---|---|---|---|
| TC01 | Open Forgot Password from loginp | Student email request form is displayedd | Login link and email form captured in browsert | Passs |
| TC02 | Submit malformed emails | Request is rejected without sending an OTPr | Local endpoint returned HTTP 400 for invalid emaild | Passs |
| TC03 | Request an OTP for the UI flowe | Six-digit OTP entry state is displayedg | UI captured with simulated request responsed | Passs |
| TC04 | Enter an invalid OTPh | An invalid/expired OTP error is displayedn | UI captured with simulated invalid responsen | Passd |
| TC05 | Verify OTP successfullyh | New and confirmation password fields are displayedt | UI captured with simulated verified responsed | Passd |
| TC06 | Complete password reset UIa | Password updated success message is displayedt | UI captured with simulated success responsed | Passd |
| TC07 | Review OTP and reset safeguardsn | OTP is hashed, time-limited, attempt-limited, and invalidated after usee | Backend controller/model source revieweds | Verifieds |
| TC08 | Review student-only password updated | Only the linked STUDENT account can be updatedy | Student email and role checks reviewed in backend modeld | Verifieds |
| TC09 | Test real SMTP and database reset end-to-endD | Registered student receives OTP and password changes in MySQLk | Not run; UI captures used simulated API responsese | Not runn |

## 4.2 Test Summary

| Test Result | Count |
|---|---|
| Total Verification Checkss | 9 |
| Passed (UI, API validation, build)) | 6 |
| Verified by source revieww | |
| Failed / Not runn | |

Overall Result: UI, syntax, targeted lint, and frontend build checks passed. Live SMTP delivery and database-backed reset testing remain unverified.

# 5. Acceptance Criteria Verification

| IDD | Acceptance Criterionn | Verificationn | Statuss |
|---|---|---|---|
| AC-0011 | Forgot Password opens student email recovery.. | Login UI inspected; email entry capturedn | Mett |
| AC-0022 | Only a registered student email can receive a reset OTP.. | Student lookup and role restriction reviewed; UI request simulatedw | Mett |
| AC-0033 | OTP is six digits, time-limited, and attempt-limited.. | OTP validation and expiry logic reviewed; UI states captureds | Mett |
| AC-0044 | New password and confirmation must match and satisfy minimum length.. | Server validation reviewedw | Mett |
| AC-0055 | New password is hashed and applied only to the linked student account.. | bcrypt hashing and student-scoped update reviewedn | Mett |
| AC-0066 | Reset session expires and cannot be reused after success.. | Token expiry and OTP deletion reviewede | Mett |
| AC-0077 | Clear error and password-reset success messages are provided.. | Invalid OTP and success UI states capturede | Mett |
| AC-0088 | Existing login and administrator authorization remain unchanged.. | Route and authentication scope reviewedn | Mett |

# 6. Evidence

The following screenshots document the student password-recovery interface. UI API responses were simulated for these captures; they do not verify live SMTP delivery or a database-backed password change.

## 6.1 Evidence 01 - Forgot Password Link

Related: AC-001

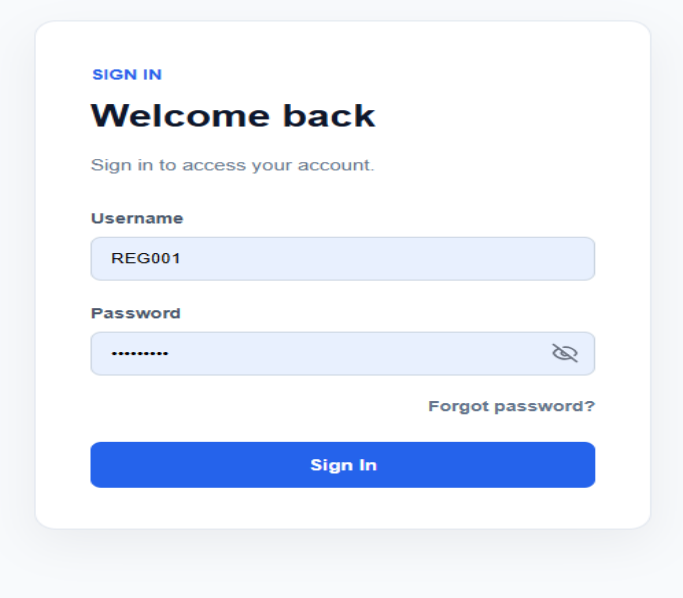



Figure 1: Login page displaying the Forgot password? link.

## 6.2 Evidence 02 - Student Email Entry

Related: AC-001, AC-002

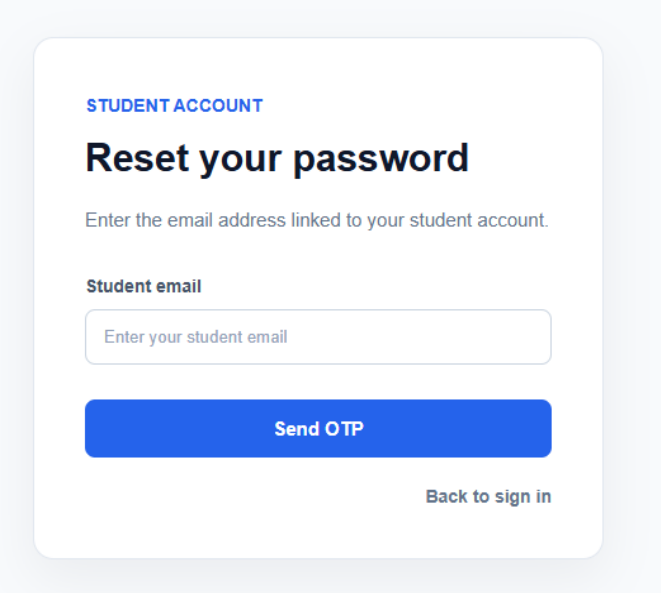



Figure 2: Student email field in the password-reset request form.

## 6.3 Evidence 03 - OTP Entry

Related: AC-003

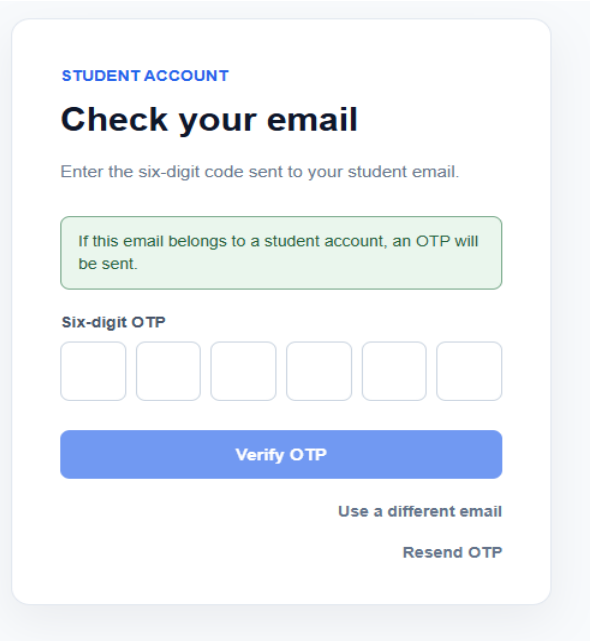



Figure 3: Six-box OTP entry form after an OTP request.

## 6.4 Evidence 04 - Invalid OTP

Related: AC-003, AC-007

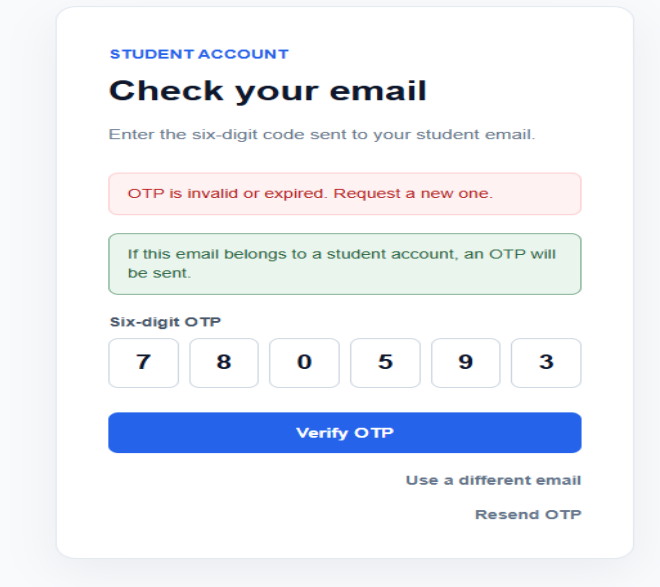



Figure 4: Error message displayed after an invalid OTP.

## 6.5 Evidence 05 - OTP Verified

Related: AC-004

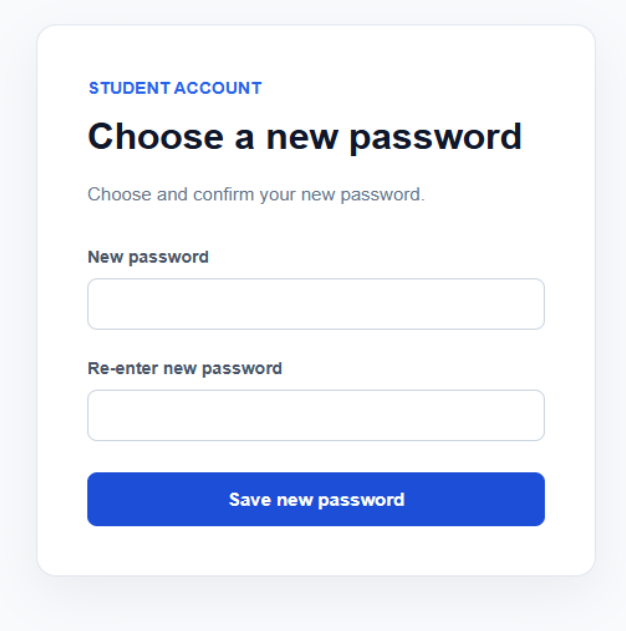



Figure 5: New-password form shown after successful OTP verification.

## 6.6 Evidence 06 - Password Reset Complete

Related: AC-005, AC-007

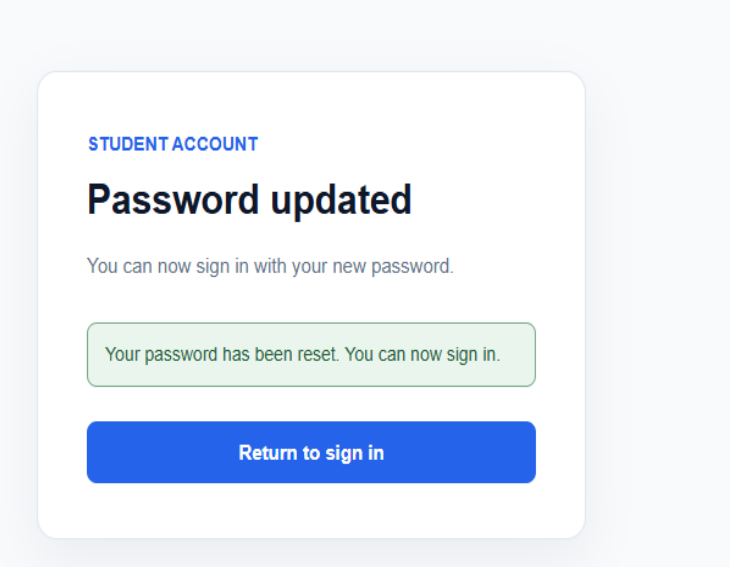



Figure 6: Success message after the password reset request completes.

# 7. Final Result

| Item | Resultt |
|---|---|
| Requirementss | Implemented; live SMTP/database verification pendingt |
| Implementationn | Completedd |
| Testingg | UI, syntax, targeted lint, build, and invalid-email checks passedn |
| Acceptance Criteriaa | All addressed; end-to-end integration not runt |
| Existing CRUDD | Unchanged; regression not runn |
| Final Statuss | Completed; integration limitation documentedd |

## 7.1 Final Summary

CR-026 adds a student-only password recovery flow. A student requests an OTP using the registered email, verifies the time-limited code, and sets a matching new password. The backend hashes OTPs and passwords, restricts updates to the linked STUDENT account, and invalidates the reset challenge after success. Existing login and administrator authorization remain unchanged.

The six screenshots document UI states with simulated API responses; they do not demonstrate live email delivery or a database-backed password change.

Other implementation issues:
No significant implementation issues identified.

Student Name: ___P.Tharanan____
Student ID: JF/ICT/24/20
Date: 15 October 2026
Signature: _____P.Tharanan_____

**~ END OF REPORT ~**